

e-Cidade Software Público

Gestão Municipal Integrada

Manual Técnico de Arquitetura de Autenticação, Recuperação Segura de Senha e Conformidade LGPD

Governança, Políticas de Acesso e Guia Operacional

Autor: Equipe de Engenharia CPD-MUNICIPAL / Microsist
Versão: 2.5 (Atualizada com Selo LGPD e Card Flutuante Responsivo)
Data: 24 de Setembro de 2026

Sumário

1	Introdução e Visão Geral	2
2	Arquitetura de Segurança e Autenticação	2
2.1	Fluxo de Login e Limite de 3 Tentativas	2
2.2	Mecanismo de Recuperação de Senha	2
3	Estrutura do Banco de Dados	3
4	Design da Interface e Conformidade LGPD	3
4.1	Card Flutuante à Direita (Glassmorphism)	3
4.2	Selo Informativo da LGPD	3
5	Guia de Operação e Resolução de Problemas	3
5.1	Desbloqueio Manual de Usuário	3
5.2	Dual Webroot e Sincronização	4
6	Conclusão	4

1 Introdução e Visão Geral

Este documento consolida as especificações arquiteturais, de segurança da informação e de conformidade legal implementadas no subsistema de autenticação e controle de acesso do ****e-Cidade**** (CPD-MUNICIPAL).

O sistema foi aprimorado para atender a três pilares estratégicos:

1. **Segurança Contra Ataques de Força Bruta:** Bloqueio automático de contas após 3 tentativas consecutivas com credenciais incorretas e commit imediato no PostgreSQL.
2. **Recuperação Segura de Senha:** Fluxo automatizado via e-mail corporativo utilizando tokens criptográficos temporários (30 minutos) e algoritmo de dispersão SHA1(MD5(.)).
3. **Conformidade Rigorosa com a LGPD:** Adequação à Lei Geral de Proteção de Dados Pessoais (Lei Federal nº 13.709/2018), com interface moderna, informativa e não-invasiva.

2 Arquitetura de Segurança e Autenticação

2.1 Fluxo de Login e Limite de 3 Tentativas

A autenticação do e-Cidade combina rotas legadas em PHP 5.6 com a camada moderna via Laravel Framework e OAuth2 Password Grant.

Regra de Bloqueio por Força Bruta

- **Tentativas 1 e 2:** O sistema registra o erro, incrementa o contador atômico em cache (`login_attempts_{usuario}`) e alerta o usuário com o número de tentativas restantes.
- **Tentativa 3:** A conta é imediatamente bloqueada no banco de dados (`db_usuarios.usuarioativo = 2`). Uma transação explícita com `DB::commit()` é executada para garantir a persistência antes do disparo da exceção `MaxLoginAttemptsException` (HTTP 403, código `E_MAX_ATTEMPTS`).
- **Ação de Interface:** A tela de login captura o erro e abre automaticamente o modal de recuperação de senha preenchendo o identificador do usuário.

2.2 Mecanismo de Recuperação de Senha

Para garantir que nenhuma brecha de segurança seja aberta:

- **Prevenção de Enumeração de Contas:** A resposta da API é genérica, confirmando o processamento sem revelar se o e-mail ou o usuário existem.
- **Validação Cruzada Estrita:** O token só é gerado se o e-mail informado coincidir exatamente com o cadastro em `configuracoes.db_usuarios.email` ou `protocolo.cgm.z01_email`.
- **Tokens Criptográficos de Uso Único:** Tokens pseudo-aleatórios com 64 caracteres hexadecimais, validade máxima de 30 minutos e invalidação imediata após redefinição.
- **Criptografia de Senhas:** Aplicação da função canônica do e-Cidade:

$$\text{Hash} = \text{SHA1}(\text{MD5}(\text{nova_senha}))$$

3 Estrutura do Banco de Dados

A persistência dos tokens de recuperação utiliza a tabela dedicada no schema de configurações:

```
CREATE TABLE configuracoes.db_usuariorecuperasenha (
  id SERIAL PRIMARY KEY,
  id_usuario INT NOT NULL,
  login VARCHAR(50) NOT NULL,
  email VARCHAR(100) NOT NULL,
  token VARCHAR(64) NOT NULL,
  expires_at TIMESTAMP NOT NULL,
  used BOOLEAN DEFAULT FALSE,
  created_at TIMESTAMP DEFAULT CURRENT_TIMESTAMP
);
CREATE INDEX idx_db_usuariorecuperasenha_token
  ON configuracoes.db_usuariorecuperasenha(token);
```

4 Design da Interface e Conformidade LGPD

4.1 Card Flutuante à Direita (Glassmorphism)

A tela de login foi remodelada para proporcionar uma experiência visual agradável, profissional e responsiva:

- **Posicionamento:** Estrutura flutuante fixada à direita com margem segura (`right: 6%`) e centralização vertical dinâmica (`display: flex; align-items: center`).
- **Fundo Translúcido:** Efeito *Glassmorphism* com `backdrop-filter: blur(16px)` e bordas arredondadas (`border-radius: 20px`).
- **Campos Otimizados:** Inputs de altura compacta (34px) com ícones integrados (`fa-user`, `fa-lock`), garantindo mais de 180px de respiro visual acima e abaixo do formulário.
- **Tratamento de Encoding:** Imunidade total a erros de acentuação (*mojibake*) através do uso integral de entidades HTML (`´`, `¸`, `˜`).

4.2 Selo Informativo da LGPD

Em atendimento à Lei nº 13.709/2018, o formulário incorpora de forma nativa e elegante o selo de privacidade:

Selo de Conformidade LGPD Integrado

Privacidade & Segurança

Ambiente em rigorosa conformidade com a LGPD (Lei Geral de Proteção de Dados Pessoais - Lei nº 13.709/2018).

5 Guia de Operação e Resolução de Problemas

5.1 Desbloqueio Manual de Usuário

Caso um administrador necessite desbloquear manualmente um usuário bloqueado por excesso de tentativas:

```
# 1. Ativar usuario no PostgreSQL
docker exec e_cidade_container psql -h localhost -p 5433 -U postgres -d
↪ e_cidade \
```

```
-c "UPDATE configuracoes.db_usuarios SET usuarioativo=1 WHERE login=
    ↪ 'usuario';"
```

```
# 2. Limpar cache de tentativas no Laravel
```

```
docker exec -w /var/www/html e_cidade_container php artisan cache:clear
```

5.2 Dual Webroot e Sincronização

Sempre que arquivos de autenticação forem modificados, a sincronização deve ocorrer simultaneamente:

- /var/www/html/ (Webroot ativa do Apache no container)
- /var/www/html/e-cidadeCPD/ (Repositório Git versionado)

6 Conclusão

As atualizações implementadas elevam o nível de segurança do e-Cidade aos padrões modernos de governança digital e proteção de dados, garantindo estabilidade, proteção contra invasões automatizadas e uma excelente experiência ao usuário final.